

Bonus 1: Interpretare Dati HTTP e DNS per Isolare l'Attore della Minaccia

Gruppo: NetRunners

Parte 1 — Investigare un attacco di SQL Injection

Passo 1: Preparazione dell'ambiente

È stata avviata la macchina virtuale Security Onion con le credenziali utente analyst / cyberops. Da terminale è stato eseguito il comando `sudo so-status` per verificare che tutti i servizi necessari (sguil, seconion-import, elasticsearch, logstash, kibana, freqserver) fossero attivi e correttamente funzionanti (stato OK per ciascuno).

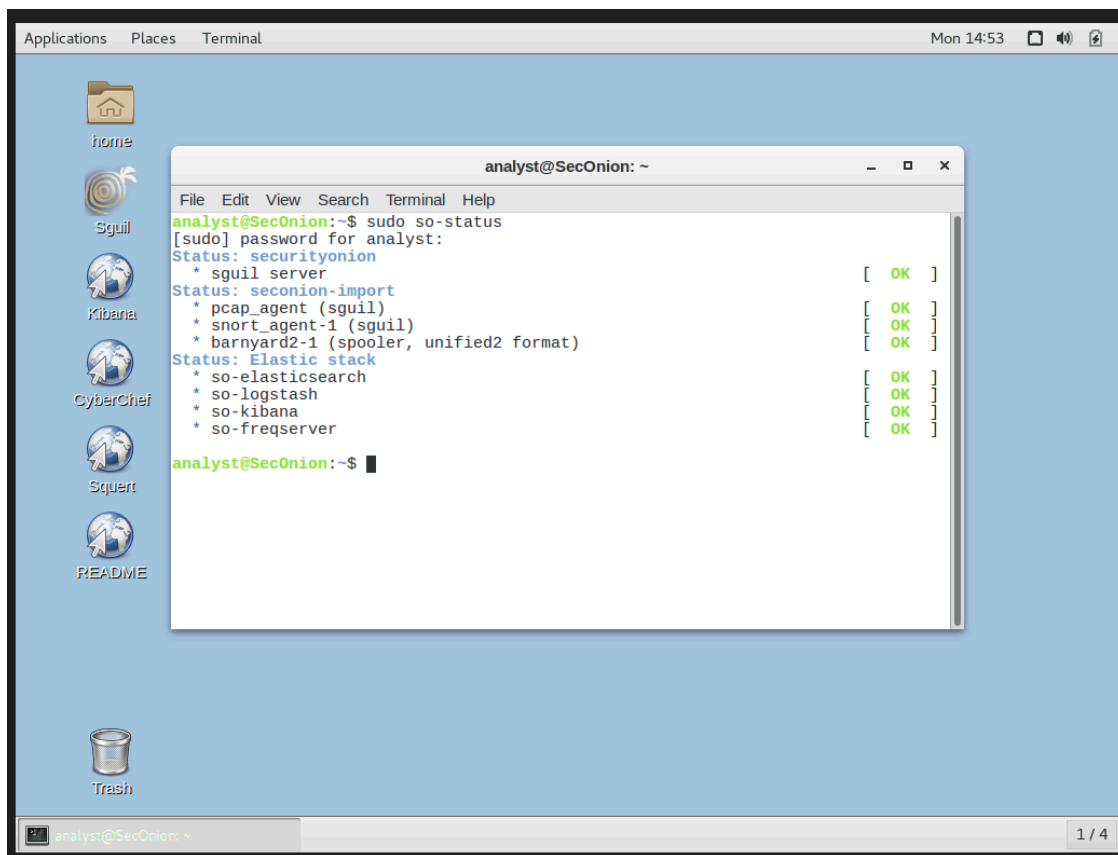


Figura 1 — Verifica dello stato dei servizi con `sudo so-status`: tutti OK.

Successivamente è stato aperto Kibana dal collegamento sul Desktop (login analyst / cyberops) e l'intervallo temporale è stato modificato da 'Last 24 hours' (impostazione predefinita) a un intervallo assoluto che copre l'intero mese di giugno 2020 (dal 1 giugno 2020 00:00:00 al 30 giugno 2020 23:59:59), poiché l'attacco è avvenuto in quel periodo.

Il totale dei log registrati nell'intero mese di giugno 2020, visibile dalla dashboard 'Overview', è risultato pari a 136, suddivisi tra le varie categorie di traffico (bro_conn: 62, bro_files: 23, bro_dns: 22, bro_http: 22).

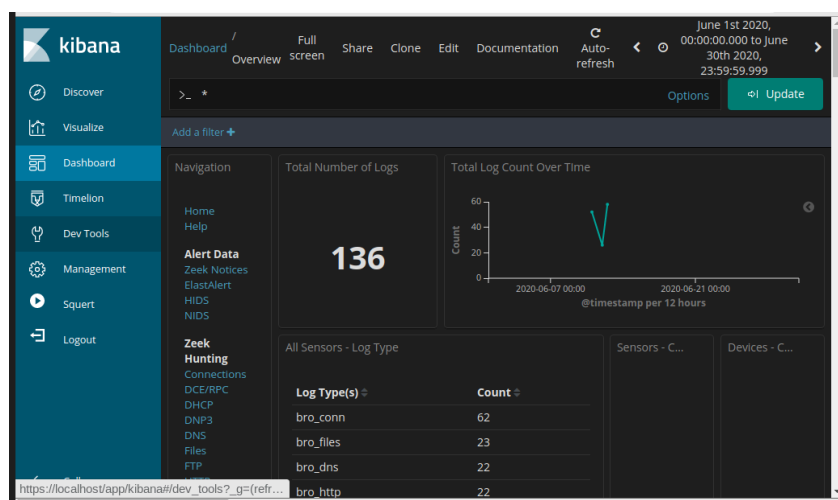


Figura 2 — Dashboard Overview: 136 log totali nel mese di giugno 2020.

Passo 2: Filtrare per traffico HTTP

Poiché l'attaccante ha avuto accesso a dati memorizzati su un server web, è stato selezionato il filtro HTTP nella sezione Zeek Hunting della dashboard. Sono comparsi 22 log HTTP totali per il mese di giugno 2020.

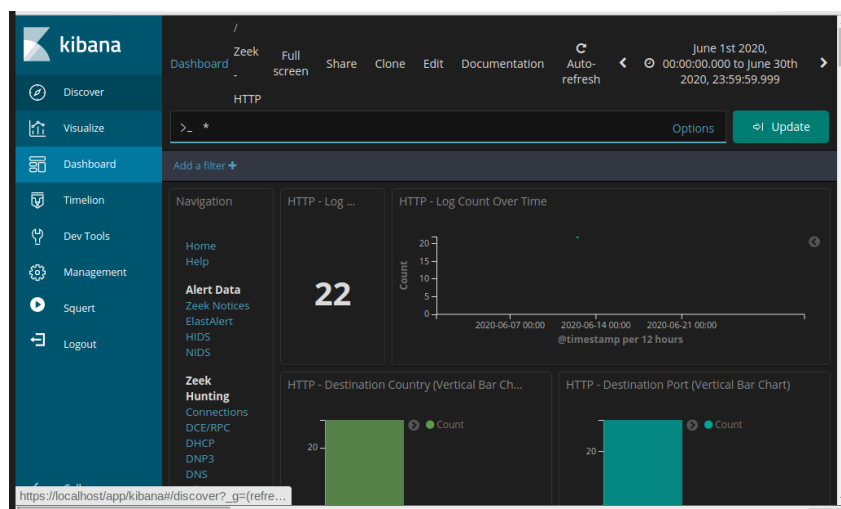


Figura 3 — Dashboard HTTP: 22 log totali, grafico Paese e Porta di destinazione.

Domanda: Qual è l'indirizzo IP sorgente?

Risposta: 209.165.200.227 (22 richieste registrate da questo indirizzo).

Domanda: Qual è l'indirizzo IP destinazione?

Risposta: 209.165.200.235 (il server web che ha ricevuto le richieste).

Domanda: Qual è il numero di porta destinazione?

Risposta: 80, la porta standard del protocollo HTTP.

HTTP - Source IP Address		HTTP - Destination IP Address	
IP Address	Count	IP Address	Count
209.165.200.227	22	209.165.200.235	22

Figura 4 — Tabelle HTTP - Source/Destination IP Address: sorgente 209.165.200.227, destinazione 209.165.200.235.

Scorrendo la tabella 'HTTP Logs' (limitata ai primi 10 risultati su 22 totali), è stato espanso il primo risultato cliccando sulla freccia accanto al timestamp, per vederne tutti i dettagli.

Domanda: Qual è il timestamp del primo risultato?

Risposta: 12 giugno 2020, 21:30:09.445.

Domanda: Qual è il tipo di evento?

Risposta: bro_http (campo event_type), cioè un evento di traffico HTTP registrato dal motore di analisi Zeek/Bro.

HTTP - Logs	
t destination_geo.region_code	US-CA
t destination_geo.region_name	California
t destination_geo.timezone	America/Los_Angeles
destination_ip	209.165.200.235
t destination_ips	209.165.200.235
# destination_port	80
t event_type	bro_http
t host	d68c9360b6ae
t ips	209.165.200.235, 209.165.200.227
t message	{ "ts": "2020-06-12T21:30:09.445030Z", "uid": "CuKeR52aPjRN7PfQd", "id": "209.165.200.227", "id.orig_p": "56194", "id.resp_h": "209.165.200.235", "resp_p": "80", "trans_depth": "1", "method": "GET", "host": "209.165.200.235", "mutillidae/index.php?page=user-info.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=&user-info-submit-button=View+Account+Details", "referrer": "http://209.165.200.235/dae/index.php?page=user-info.php", "version": "1.1", "user_agent": "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0", "request_len": "0", "response_body_len": "23665", "status_code": "200", "status_msg": "OK", "s": ["HTTP::URI_Sqli"], "resp_fuids": ["FEvWs63HqvCqth3LH1"], "resp_mime": ["text/html"] }
t method	GET
path	/nsm/import/bro/bro-W5Ldfbf0/http.log

Figura 5 — Dettaglio della voce di log espansa: destination_port 80, event_type bro_http.

Domanda: Cosa è incluso nel campo message? Cosa significa il campo uri?

Risposta: Il campo message contiene l'intera richiesta HTTP GET fatta dal client al server, in formato JSON. Il campo uri al suo interno è il seguente:
 "/mutillidae/index.php?page=user-info.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=&user-info-submit-button=View+Account+Details". Il messaggio riporta anche il tag "HTTP::URI_Sqli", che indica che il sistema di rilevamento ha già classificato automaticamente questa richiesta come un tentativo di SQL Injection.

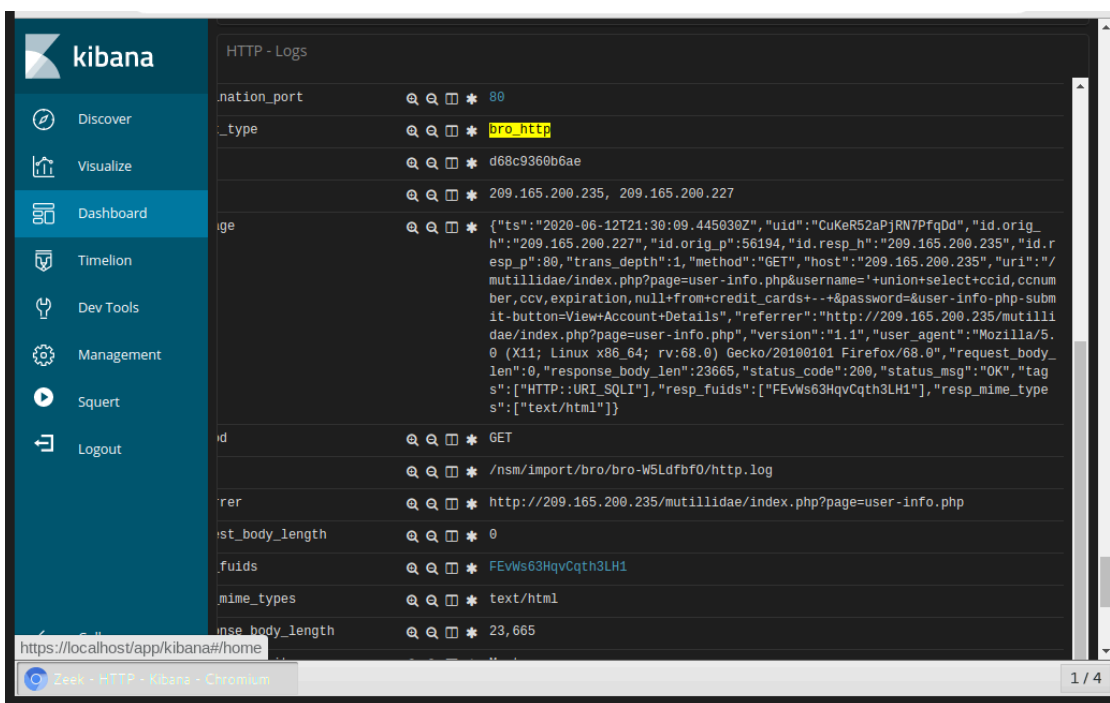


Figura 6 — Campo message completo con la richiesta GET e il tag HTTP::URI_SQLI.

Significato: al posto di un normale username, l'attaccante ha scritto un comando SQL (UNION SELECT) per costringere il database a restituire, invece dei dati di login, le colonne ccid, ccnumber, ccv ed expiration della tabella credit_cards — cioè i dati delle carte di credito memorizzate nel database del sito.

Passo 3: Analisi della trascrizione con capME!

Cliccando sul valore del campo `_id` della voce di log, si è aperta una nuova scheda con capME!, lo strumento che mostra la trascrizione completa della comunicazione di rete (pcap). Il testo blu rappresenta le richieste inviate dalla sorgente (l'attaccante), mentre il testo rosso rappresenta le risposte del server web di destinazione.

Nella sezione 'Log entry' iniziale è confermata la stringa di SQL injection già individuata: `username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=`. Le parole chiave UNION e SELECT sono comandi SQL usati per estrarre dati da un database: qui vengono usati per bypassare l'autenticazione ed estrarre direttamente i dati sensibili.

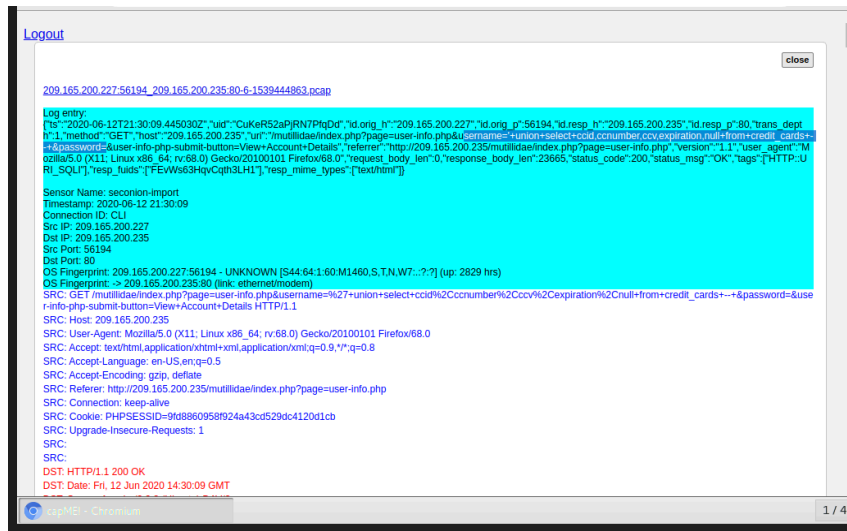


Figura 7 — capME!: log entry con la stringa di SQL injection (union+select) evidenziata.

Usando la funzione di ricerca (Ctrl-F) per la parola 'username' all'interno della trascrizione, scorrendo le 10 occorrenze trovate, più avanti nel testo (nella parte di risposta del server, colorata in rosso) sono comparsi diversi campi Username, Password e Signature ripetuti più volte: si tratta dei dati restituiti dal database in seguito all'attacco, cioè i dati effettivamente esfiltrati (in realtà numeri di carta di credito, CVV e date, mostrati con le etichette generiche dell'applicazione vulnerabile).

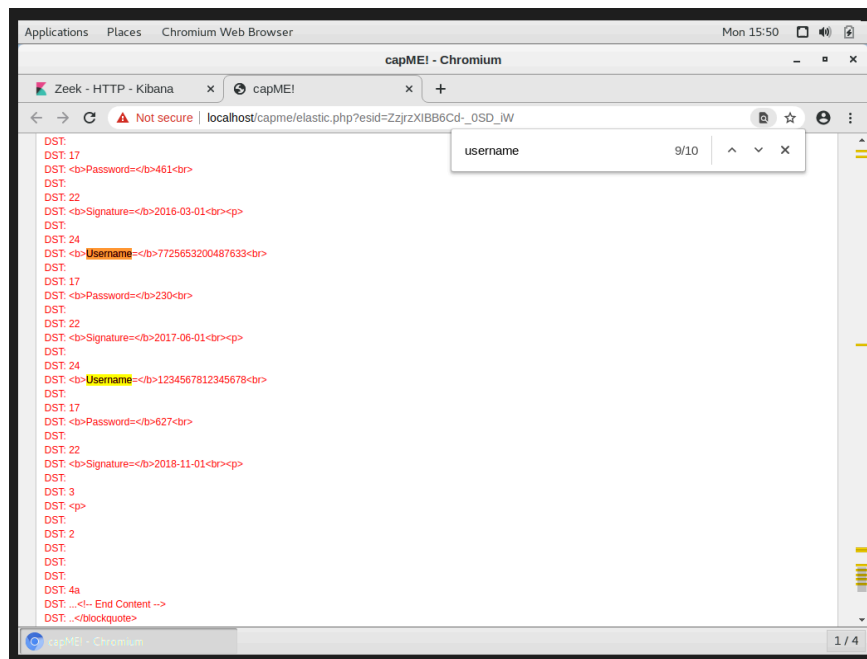


Figura 8 — Ultimi record trovati, con conferma "5 records found" (9/10).

Domanda: Fornisci alcuni esempi di nome utente, password e firma che sono stati esfiltrati.

Risposta: Di seguito sono riportati i 5 record trovati nella trascrizione:

Username (numero carta)	Password (CVV)	Signature (scadenza)
4444111122223333	745	2012-03-01
7746536337776330	722	2015-04-01
8242325748474749	461	2016-03-01
7725653200487633	230	2017-06-01
1234567812345678	627	2018-11-01

Parte 2 — Analizzare l'esfiltrazione di dati via DNS

In questa seconda parte è stata investigata un'anomalia notata da un amministratore di rete: query DNS anormalmente lunghe, con sottodomini dall'aspetto sospetto.

Passo 1: Filtrare per traffico DNS

Tornando alla schermata Home, mantenendo l'intervallo temporale su giugno 2020. È stato selezionato DNS nella sezione Zeek Hunting. Il totale dei log DNS registrati nel mese è risultato pari a 22, con porta di destinazione 53 (la porta standard del protocollo DNS).

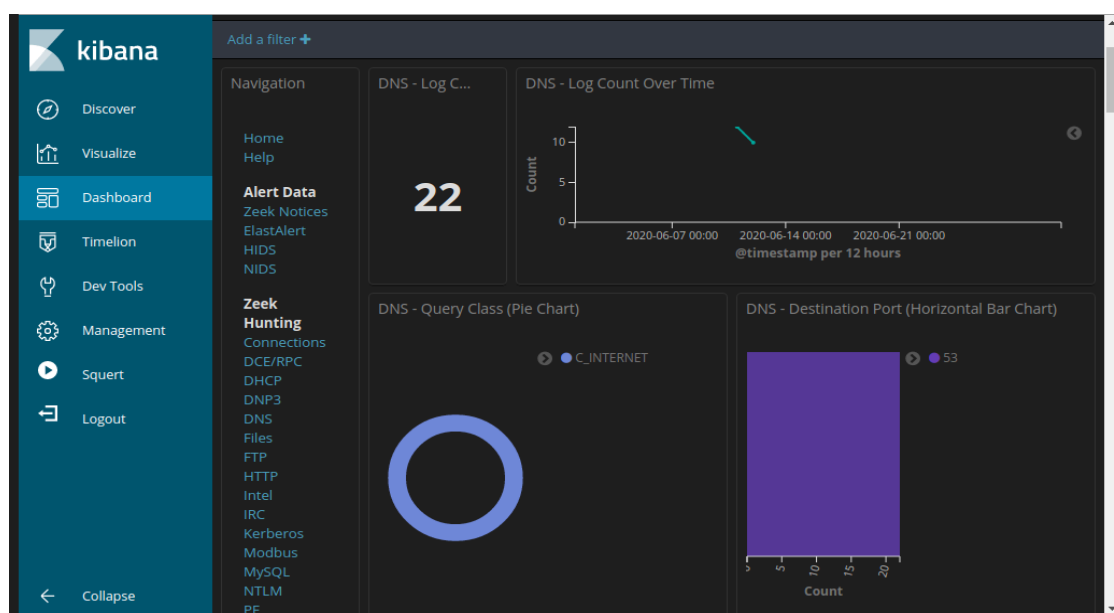


Figura 9 — Dashboard DNS: 22 log totali, grafico a torta Query Class e porta di destinazione 53.

Passo 2: Rivedere le voci DNS

Scorrendo la dashboard sono stati osservati i principali client e server DNS coinvolti, in base al numero di richieste/risposte registrate:

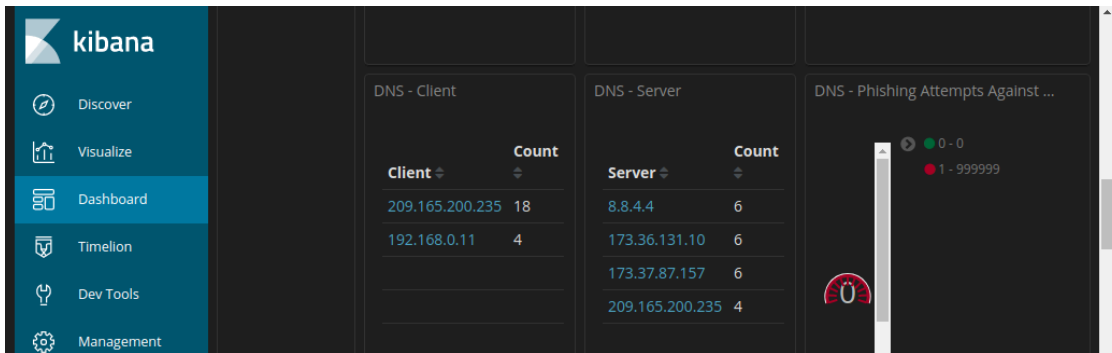


Figura 10 — Tabelle DNS - Client e DNS - Server, con contatore tentativi di phishing a 0.

DNS - Client (IP)	Conteggio
209.165.200.235	18
192.168.0.11	4

DNS - Server (IP)	Conteggio
8.8.4.4	6
173.36.131.10	6
173.37.87.157	6
209.165.200.235	4

Il numero di tentativi di phishing DNS (DNS pharming/spoofing/poisoning) rilevato è risultato pari a 0.

Scorrendo ulteriormente è comparso l'elenco delle query DNS principali per dominio: alcune di esse presentavano sottodomini insolitamente lunghi collegati al dominio ns.example.com, un comportamento anomalo rispetto a normali richieste DNS (che di solito hanno sottodomini brevi e leggibili, come 'www' o 'mail').

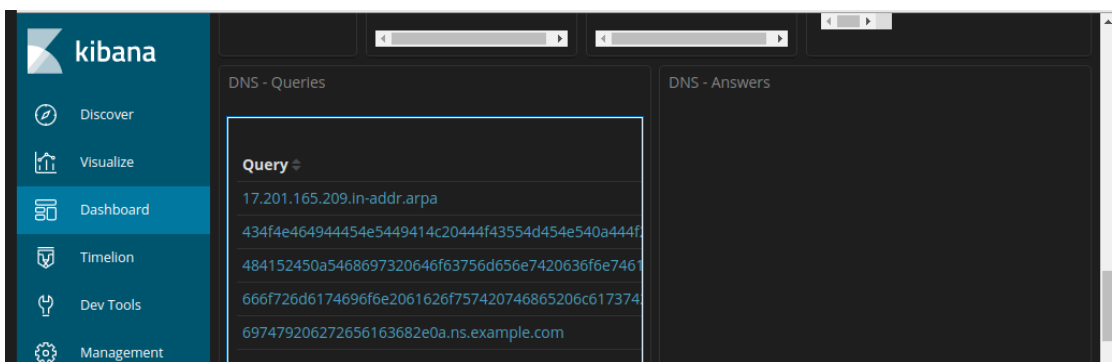


Figura 11 — Elenco DNS - Queries non filtrato: si notano le lunghe stringhe esadecimali legate a ns.example.com.

Inserendo 'example.com' nella barra di ricerca e cliccando su Update, il numero di log si è ridotto a 4, isolando così le sole query sospette dirette a quel dominio.

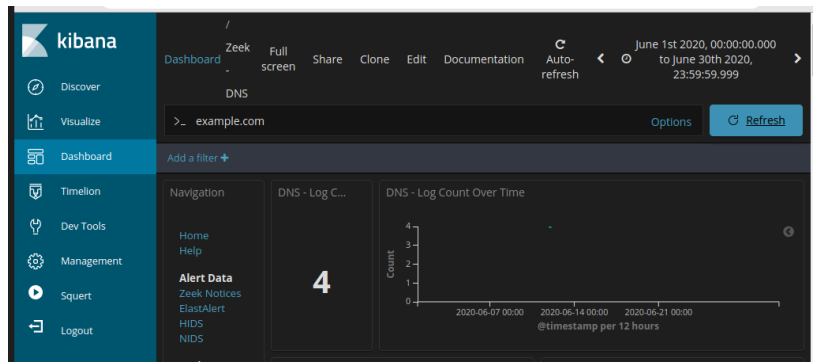


Figura 12 — Dopo l'aggiornamento: il conteggio dei log si riduce a 4.

Passo 3: Determinare i dati esfiltrati

Le 4 query uniche verso example.com presentavano sottodomini composti esclusivamente da caratteri 0-9 e a-f: la caratteristica tipica della notazione esadecimale, che indica testo codificato piuttosto che nomi di sottodominio legittimi.

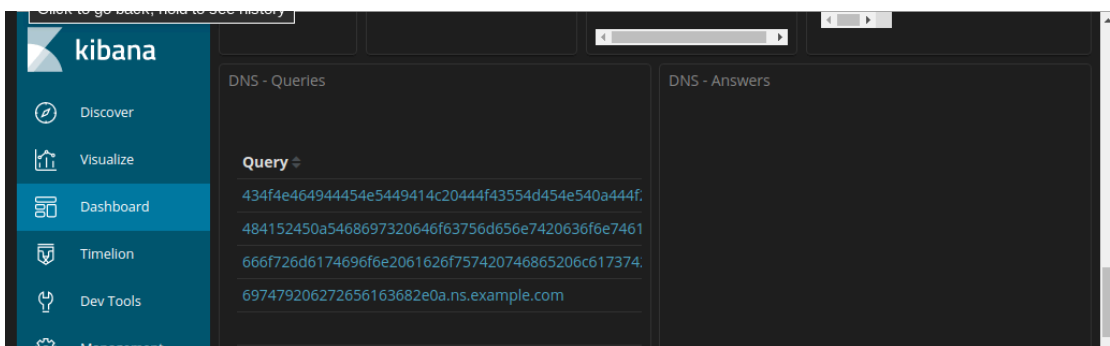


Figura 13 — Le 4 query DNS filtrate verso example.com, con i sottodomini esadecimali.

Le query sono state esportate in formato CSV tramite il link 'Export: Raw', scaricando il file DNS - Queries.csv nella cartella /home/analyst/Downloads. Il file è stato aperto con l'editor di testo gedit e ripulito, rimuovendo tutto il testo attorno alla parte esadecimale di ciascun sottodominio (compreso '.ns.example.com', le virgolette e la parte finale ',1)'), lasciando solo le 4 righe di caratteri esadecimali puri:

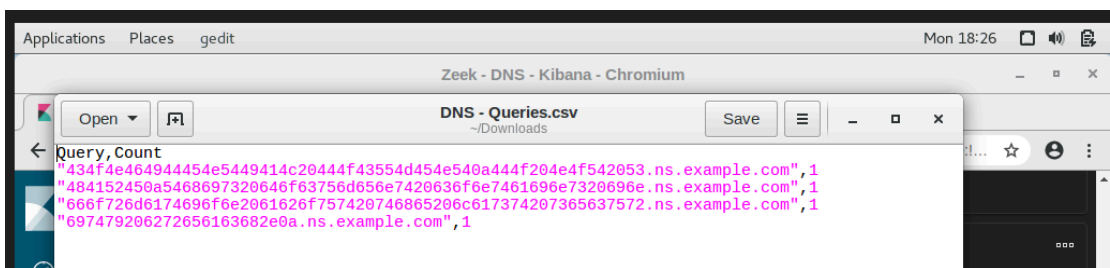


Figura 14 — File DNS - Queries.csv originale, aperto in gedit, prima della pulizia.

434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053

484152450a5468697320646f63756d6556e7420636f6e7461696e73206e

666f726d61746966f6e2061626f757420746865206c6173742073656375726974792e

6974792062726561636368656163682e0a

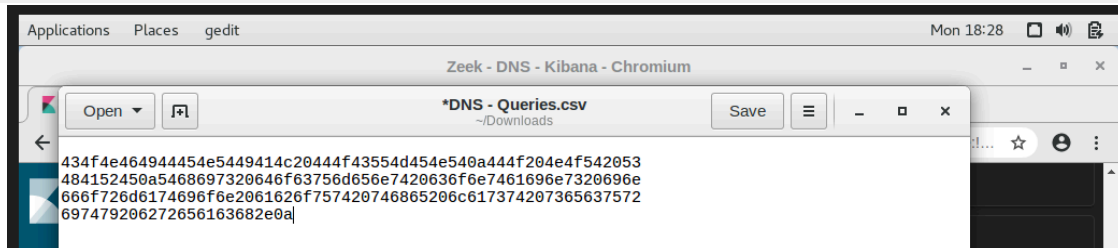


Figura 15 — File ripulito: restano solo le 4 righe di caratteri esadecimali puri.

A questo punto, da terminale, è stato usato il comando `xxd` per decodificare il contenuto esadecimale del file e salvarlo in un nuovo file chiamato `secret.txt`, poi visualizzato con il comando `cat`:

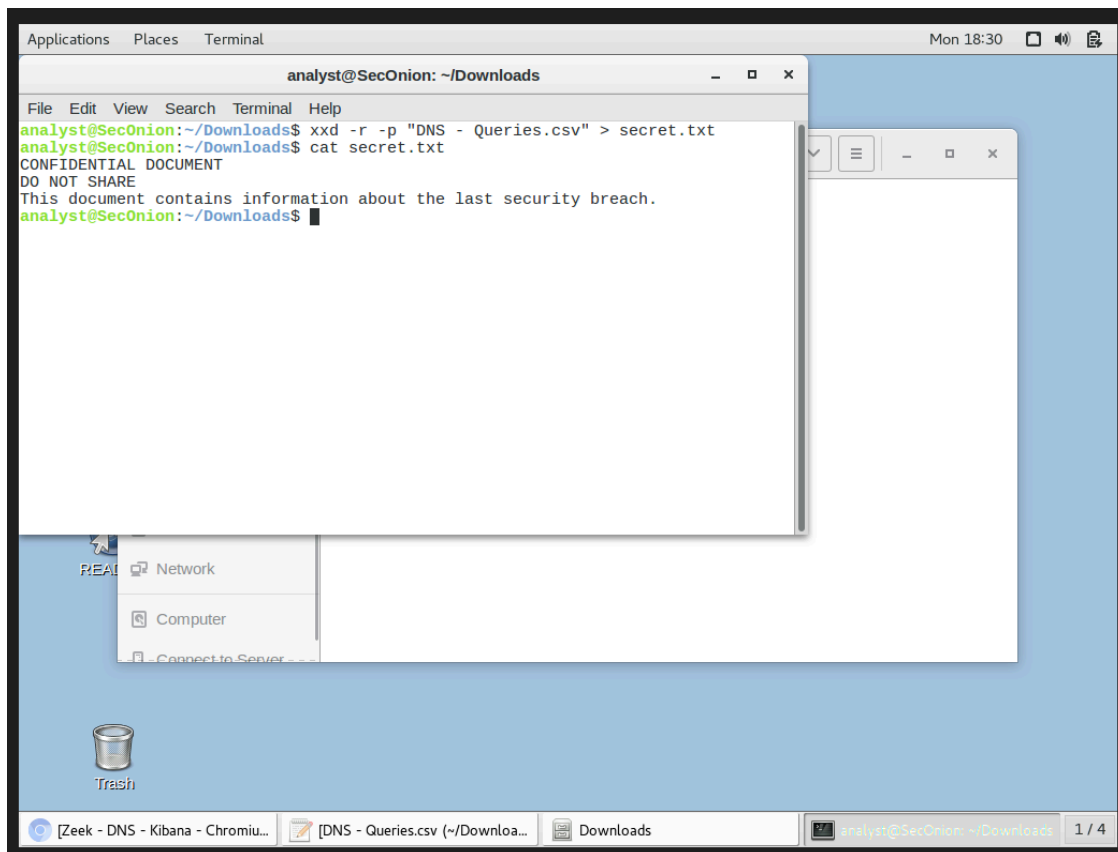


Figura 16 — Terminale: decodifica con `xxd` e contenuto finale di `secret.txt`.

Domanda: I sottodomini delle query DNS erano sottodomini reali? Se no, qual è il testo?

Risposta: No, non erano sottodomini reali. Erano una sequenza di caratteri esadecimali usata per nascondere un messaggio di testo. Una volta decodificato, il testo risulta essere:

"CONFIDENTIAL DOCUMENT. DO NOT SHARE. This document contains information about

the last security breach." (in italiano: "Documento riservato. Non condividere. Questo documento contiene informazioni sull'ultima violazione di sicurezza.")

Domanda: Cosa implica questo risultato riguardo a queste particolari richieste DNS? Qual è il significato più ampio?

Risposta: Implica che quelle richieste DNS non servivano a risolvere un vero nome a dominio, ma erano state create appositamente per portare fuori dalla rete (esfiltrare) un documento riservato, camuffandolo da normale traffico di navigazione. Il significato più ampio è che non tutto il traffico DNS 'insolito' va ignorato: anche un protocollo considerato innocuo e quasi sempre permesso dai firewall può essere sfruttato come canale nascosto per far uscire dati sensibili da un'organizzazione senza destare sospetti.

Domanda: Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

Risposta: Molto probabilmente un malware o uno script installato sul sistema compromesso, che ha preso il documento riservato, lo ha convertito in esadecimale e lo ha suddiviso in più query DNS verso un dominio controllato dall'attaccante (ns.example.com). Il DNS è stato scelto come mezzo di esfiltrazione perché il suo traffico è quasi sempre necessario al funzionamento della rete e quindi viene lasciato passare liberamente dai firewall, oltre a essere raramente ispezionato in profondità dai sistemi di sicurezza tradizionali: questo lo rende un canale efficace e difficile da individuare per portare dati fuori dalla rete senza attivare allarmi.